

الوحدة 06: PKI والشهادات الرقمية

(PKI (Public Key Infrastructure

البنية التحتية للمفتاح العام (PKI) هي إطار من السياسات والبرامج والأجهزة لإدارة المفاتيح العامة والشهادات الرقمية. مكوناتها:

- **CA (Certificate Authority):** جهة تصدر الشهادات الرقمية وتوثقها. مثل Let's Encrypt، DigiCert.
- **RA (Registration Authority):** تتحقق من هوية مقدم الطلب قبل إرسال الطلب إلى CA.
- **CRL (Certificate Revocation List):** قائمة الشهادات الملغاة.
- **OCSP (Online Certificate Status Protocol):** بروتوكول للتحقق الفوري من صلاحية الشهادة.

الشهادات الرقمية (Digital Certificates)

شهادة رقمية (X.509) هي مستند إلكتروني يربط هوية (شخص، موقع، جهاز) بمفتاح عام. تحتوي على:

- الموضوع (Subject): لمن صدرت الشهادة
- الجهة المصدرة (Issuer): من أصدرها (CA)
- المفتاح العام (Public Key)
- تاريخ الانتهاء (Validity Period)
- التوقيع الرقمي لل-CA
- رقم التسلسل (Serial Number)

توليد شهادة موقع ويب - خطوة بخطوة

1. توليد مفتاح خاص:

```
openssl genrsa -out myserver.key 2048
```

2. إنشاء طلب شهادة (CSR):

```
openssl req -new -key myserver.key -out myserver.csr -subj "/C=SA/ST=Riyadh/L=Riyadh/O=
```

- **req -new:** إنشاء طلب شهادة جديد.
- **key myserver.key:** يستخدم المفتاح الخاص الذي أنشأناه.
- **subj:** معلومات الهوية. C=البلد (SA للسعودية)، ST=المنطقة، L=المدينة، O=المؤسسة، CN=اسم النطاق.

3. توقيع الشهادة ذاتياً (Self-Signed) للاختبار:

```
openssl x509 -req -days 365 -in myserver.csr -signkey myserver.key -out myserver.crt
```

- **req-x509**: تحويل CSR إلى شهادة X.509.
- **days 365**: صلاحية الشهادة سنة واحدة.
- **signkey myserver.key**: توقيع الشهادة بالمفتاح الخاص.

قائمة إلغاء الشهادات (CRL) و OCSP

- **CRL (Certificate Revocation List)**: قائمة بالأرقام التسلسلية للشهادات الملغاة. تنشرها CA بشكل دوري. عيبها: التأخير بين الإلغاء والنشر.
- **OCSP (Online Certificate Status Protocol)**: بروتوكول يتحقق فوراً من صلاحية شهادة معينة بإرسال استعلام إلى OCSP Responder. أسرع وأحدث من CRL.

مصافحة (TLS Handshake)

عملية إنشاء اتصال آمن بين المتصفح والخادم:

1. **Client Hello**: المتصفح يرسل قائمة بخوارزميات التشفير المدعومة وإصدار TLS.
2. **Server Hello**: الخادم يختار خوارزمية التشفير ويرسل شهادته الرقمية.
3. **التحقق من الشهادة**: المتصفح يتحقق من أن الشهادة موقعة من CA موثوقة، غير منتهية الصلاحية، وغير ملغاة (يستخدم OCSP/CRL).
4. **Key Exchange**: يتم تبادل المفاتيح باستخدام Diffie-Hellman أو RSA.
5. **Session Keys**: يتم إنشاء مفاتيح جلسة متماثلة (مثل AES-256) لتشفير باقي الاتصال.
6. **Secure Communication**: يبدأ الاتصال المشفر.

التحقق من شهادة موقع ويب

عرض تفاصيل شهادة موقع:

```
openssl s_client -connect google.com:443 -showcerts
```

- **s_client**: عميل SSL/TLS لاختبار الاتصالات.
- **connect google.com:443**: الاتصال بالموقع على المنفذ 443 (HTTPS).
- **showcerts**: عرض جميع الشهادات في سلسلة الشهادة.

الأمر يعرض سلسلة الشهادة الكاملة، تاريخ الانتهاء، والجهة المصدرة.

فحص رؤوس HTTP بالأمر **curl**:

```
curl -I https://example.com
```

- **-I**: جلب الرؤوس فقط (Headers) دون تحميل الصفحة.
- يعرض معلومات الأمان مثل Strict-Transport-Security، Content-Security-Policy.

(Quick Quiz (MCQ

.1 :PKI stands for

- a) Private Key Infrastructure
- b) Public Key Infrastructure
- c) Protected Key Interface
- d) Public Knowledge Initiative

Answer: b

.2 ?What is the difference between CRL and OCSP

- a) CRL is faster than OCSP
- b) OCSP provides real-time revocation status; CRL is a periodic list
- c) They are the same
- d) CRL is more secure than OCSP

Answer: b

.3 ?Which OpenSSL command creates a CSR

- a) openssl genrsa
- b) openssl req -new
- c) openssl x509
- d) openssl s_client

Answer: b

.4 ?In a TLS Handshake, which comes first

- a) Server Hello
- b) Client Hello
- c) Key Exchange
- d) Certificate verification

Answer: b

.5 :CN in a digital certificate stands for

- a) Company Name
- b) Common Name
- c) Certificate Number
- d) Country Name

Answer: b